

MAPEO DE PREGUNTAS A REQUISITOS NORMATIVOS

Matriz Integral: Encuesta ↔ Estándares/Regulaciones

Versión: 1.0 | Enero 2026

MAPEO GENERAL

Cada pregunta de encuesta se alinea con requisitos específicos de:

- **NIST CSF 2.0** (marco estratégico)
- **ISO 27001:2022** (certificación)
- **NIS2** (regulación UE)
- **ENS** (España - sector público)
- **GDPR** (protección datos)
- **CRA** (ciberresiliencia productos)
- **CMMC 2.0** (DoD contractors)

SECCIÓN 2: GOBERNANZA (GOBERNAR)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	ENS	GDPR	CRA	Auditabl e
2.1	Política Ciberseg uridad	GV-PO (Política s)	5.1 (Direcció n)	Art. 19 (Política s)	Cap. 5 (Normat iva)	Art. 32 (Medida s)	-	✓ Docume ntación
2.2	Respons abilidad es/CISO	GV-OC (Oversig ht)	5.3 (Respon sabilidad)	Art. 19 (Gobern anza)	Cap. 5 (Organis mos)	Art. 33 (Notifica ción)	-	✓ Organigr ama
2.3	Cumpli miento NIS2/IS O	GV-CO (Complia nce)	5.2 (Cumpli miento)	Arts. 19- 26 (Todo)	Caps. 1-7 (Todo)	Arts. 6, 32-34	Art. 4	✓ Certifica dos
2.4	Modelo FAIR/Ri esgos	GV-RI (Risk)	5.4 (Identifi cación)	Art. 19 (Riesgos)	Cap. 5 (Análisis)	Art. 32	Art. 4	✓ Análisis formal
2.5	Presupu esto	GV-RM (Resourc e)	5.4 (Recurso s)	Art. 19 (Recurso s)	Cap. 5 (Presup uesto)	Implícito	Implícito	✓ Presupu esto anual

SECCIÓN 3: IDENTIFICACIÓN DE RIESGOS (IDENTIFICAR)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
3.1	Inventario Activos	ID-AM (Asset Mgmt)	5.9 (Cadena)	Art. 20 (Identificación)	✓ CMDB, ITSM
3.2	Escaneo Vulnerabilidades	ID-VA (Vulnerabilidades)	5.11 (Control interno)	Art. 20 (Evaluación)	✓ Reportes scan
3.3	Ciclo de Vida Vuln.	ID-RM (Risk Mgmt)	5.12 (Cambios)	Art. 20 (Gestión)	✓ Tickets remediación
3.4	CVSS/EPSS	ID-VA (Vulnerabilidades)	5.11 (Análisis)	Art. 20 (Priorización)	✓ Dashboard VM
3.5	Gap Analysis	ID-RA (Risk Assessment)	5.4 (Evaluación)	Art. 19 (Evaluación)	✓ Matriz gaps

SECCIÓN 4: PRUEBAS DE PENETRACIÓN (PROTEGER)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
4.1	Programa Pentest	PR-AC (Access)	5.15 (Testing)	Art. 21 (Validación)	✓ Reportes pentest
4.2	Scope Testing	PR-AC (Coverage)	5.15 (Cobertura)	Art. 21 (Evaluación)	✓ Alcance documentado
4.3	Resultados Hallazgos	PR-AC (Outcomes)	5.15 (Remediación)	Art. 21 (Resultados)	✓ Matriz hallazgos
4.4	Post-Remediation Testing	PR-AC (Validation)	5.15 (Validación)	Art. 21 (Cierre)	✓ Re-test confirmado

SECCIÓN 5: SIEM Y MONITORIZACIÓN (DETECTAR)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
5.1	Arquitectura SIEM	DE-CM (Monitoring)	8.4 (Monitorización)	Art. 23 (Detección)	✓ SIEM en producción
5.2	Fuentes Centralizadas	DE-CM (Coverage)	8.4 (Cobertura)	Art. 23 (Visibilidad)	✓ Logs centralizados
5.3	Detección Amenazas	DE-AE (Analysis)	8.4 (Análisis)	Art. 23 (Análisis)	✓ Reglas detección
5.4	MTTD/Métricas	DE-CM (Performance)	8.4 (SLA)	Art. 23 (Tiempo)	✓ Métricas SIEM
5.5	Integración SOAR	DE-RP (Response)	8.4 (Automación)	Art. 23 (Orquestación)	✓ Playbooks SOAR

SECCIÓN 6: RESPUESTA A INCIDENTES (RESPONDER)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	GDPR	Auditable
6.1	Plan Respuesta	RS-PL (Planning)	7.3 (Procedimientos)	Art. 24 (Procedimientos)	Art. 33	✓ Plan documentado
6.2	Equipo Estructura	RS-PL (Team)	7.3 (Responsabilidades)	Art. 24 (Equipo)	Art. 33	✓ Organigrama crisis
6.3	Notificación Plazos	RS-IM (Communication)	7.3 (Comunicación)	Art. 24 (Notificación 24/72/30h)	Art. 33 (72h)	✓ Procedimiento timers
6.4	MTTD/ MTTC/ MTTR	RS-IM (Metrics)	7.3 (SLA)	Art. 24 (Tiempo)	Art. 33	✓ Histórico respuestas

SECCIÓN 7: CAPACITACIÓN (PROTEGER)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	GDPR	Auditable
7.1	Programa Conciencia	PR-AT (Training)	6.2 (Competencia)	Art. 22 (Conciencia)	Art. 32	✓ LMS registros
7.2	Contenidos	PR-AT (Coverage)	6.2 (Temas)	Art. 22 (Contenidos)	Art. 32	✓ Curriculum
7.3	Phishing Simulaciones	PR-AT (Testing)	6.2 (Evaluación)	Art. 22 (Testing)	Art. 32	✓ Reportes simulación
7.4	Roles Especializados	PR-AT (High-Risk)	6.2 (Roles críticos)	Art. 22 (Diferenciada)	Art. 32	✓ Certificados especiales
7.5	Métricas Participación	PR-AT (Metrics)	6.2 (Métricas)	Art. 22 (Medición)	Art. 32	✓ Dashboard participación

SECCIÓN 8: INFRAESTRUCTURA TÉCNICA (PROTEGER)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	CRA	Auditable
8.1	Arquitectura Defensiva	PR-AC (Defense)	5.1-5.22 (Controles)	Art. 21 (Medidas técnicas)	Art. 4-10	✓ Diagrama seguridad
8.2	MFA/Identidad	PR-AC (Authentication)	5.15 (Autenticación)	Art. 21 (MFA)	Art. 7	✓ Política MFA
8.3	Parcheo	PR-MA (Maintenance)	5.14 (Cambios)	Art. 21 (Parches)	Art. 9	✓ SLA parches
8.4	Encriptación	PR-DS (Data Security)	5.13 (Protección datos)	Art. 21 (Cifrado)	Art. 8	✓ Política criptografía

SECCIÓN 9: CONTINUIDAD Y RECUPERACIÓN (RECUPERAR)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
9.1	Plan DR	RC-PL (Planning)	7.5 (Continuidad)	Art. 25 (Recuperación)	✓ Plan documentado
9.2	RTO/RPO	RC-PL (Objectives)	7.5 (Objetivos)	Art. 25 (Tiempos ≤72h)	✓ Matriz RTO/RPO
9.3	Backup	RC-IM (Recovery)	7.4 (Backups)	Art. 25 (Recuperación)	✓ Procedimiento backup

SECCIÓN 10: SUPPLY CHAIN (IDENTIFICAR/PROTEGER)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
10.1	Evaluación Proveedores	ID-RM (SCRM)	5.19 (Proveedores)	Art. 28 (SCRM)	✓ Cuestionarios
10.2	Cláusulas Contratos	PR-CT (Supplier Mgmt)	5.20 (Obligaciones)	Art. 28 (Requisitos)	✓ Contratos adjuntos
10.3	SBOM	ID-AM (SBOM)	5.9 (Dependencias)	Art. 28 (Composición)	✓ SBOM recopilados

SECCIÓN 11: OT/SCADA (TODOS LOS DOMINIOS)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
11.1	Controles OT	PR-AC (OT-specific)	5.1 (Segregación)	Art. 21 (OT mandatorio)	✓ Arquitectura OT
11.2	IoT/ Dispositivos	PR-AC (IoT)	5.9 (Inventario)	Art. 21 (Cobertura)	✓ Inventario IoT

SECCIÓN 12: ANÁLISIS FINANCIERO (GV/TODOS)

# Pregunta	Encuesta	NIST	ISO 27001	NIS2	Auditable
12.1	Cuantificación FAIR	GV-RI (Risk Mgmt)	5.4 (Análisis)	Art. 19 (Riesgos €)	✓ Matriz FAIR
12.2	ROI/ROSI	GV-RM (Investment)	5.4 (Justificación)	Implícito (Business case)	✓ Análisis ROI
12.3	Costo Incidentes	GV-RI (Impact)	5.4 (Impacto real)	Implícito (Evidencia)	✓ Histórico costos

MATRIZ RESUMEN: COBERTURA ESTÁNDAR

Estándar	Cobertura %	Secciones Clave	Cumplimiento
NIST CSF 2.0	100%	2-12 (todos)	Integral
ISO 27001:2022	80%	2, 3, 4, 5, 8, 9	Alto
NIS2	100%	2-11 (requisitos)	Integral
ENS (sector público)	100%	2-9 (públicos)	Integral
GDPR	90%	6, 7, 9 (datos)	Alto
CRA	70%	4, 8 (productos)	Productos
CMMC 2.0	50%	2-5, 8, 9	Nivel 1-2

EJEMPLO: CÓMO USAR ESTA MATRIZ EN AUDITORÍA

Auditor externo: "¿Cumplen NIS2 Art. 24 (Respuesta a incidentes)?"

Respuesta:

1. Buscar en matriz "Sección 6" (Respuesta a Incidentes)
2. Preguntas 6.1-6.4 alignan con Art. 24 NIS2
3. Auditable con: Plan documentado, organigrama crisis, procedimientos timers, histórico respuestas
4. IGM Dominio RS debe ser ≥ 3.0 para cumplimiento NIS2

Conclusión: Preguntas específicas → Evidencia auditoria → Cumplimiento demostrables

Fin del Mapeo Normativo

Esta matriz permite a auditorías internas/externas validar específicamente qué preguntas responden a qué requisitos regulatorios.